

LABORATORIO SHADOWMAP

Primero analizamos que las interfaces de red ya que solo tenemos como información inicial tenemos acceso al entorno del atacante que es usuario pentester y la ip 127.0.0.1 con el puerto 2222

Al conectarnos verificamos las interfaces de red el cual tenemos una llamada br-6704d99945ab con la dirección 10.30.3.1/24

```

3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 96:f5:68:84:31:61 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
15: br-0abcd93dae0f: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 12:92:e4:01:b6:ee brd ff:ff:ff:ff:ff:ff
    inet 10.30.3.1/24 brd 10.30.3.255 scope global br-0abcd93dae0f
        valid_lft forever preferred_lft forever
    inet6 fe80::1092:e4ff:fe01:b6ee/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

```

Realizamos un escaneo de la red de esta manera sabemos cuantos host activos aparecen. Usaremos el parámetro -sn que significa (Skip port scan) esta opción le decimos a nmap que solo descubra hosts activos y que no escanee los puertos de esos hosts, es más rápido y menos intrusivo.

También usaremos la opción -PS (TCP SYN Ping) especifica el tipo de sondeo que usará nmap para descubrir hosts, este envía un paquete TCP SYN (el primer paso de una conexión TCP) a un puerto en específico que por defecto es el 80 de cada IP, si el host responde con un SYN/ACK o un RST significa que está activo.

sudo nmap -sn -PS 10.30.3.0/24

```

pentester@attacker:~/Scripts/Module_3$ sudo nmap -sn -PS 10.30.3.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-19 14:12 UTC
Nmap scan report for 10.30.3.1
Host is up (0.000081s latency).
MAC Address: B2:B9:D9:62:21:88 (Unknown)
Nmap scan report for shadowmap-dns.shadowmap_net (10.30.3.10)
Host is up (0.000037s latency).
MAC Address: 0E:2D:BE:29:24:74 (Unknown)
Nmap scan report for shadowmap-target.shadowmap_net (10.30.3.20)
Host is up (0.000068s latency).
MAC Address: 76:44:DA:6C:0B:8E (Unknown)
Nmap scan report for shadowmap-mail-storage.shadowmap_net (10.30.3.25)
Host is up (0.000018s latency).
MAC Address: EE:E9:B9:A5:0F:17 (Unknown)
Nmap scan report for shadowmap-whois.shadowmap_net (10.30.3.35)
Host is up (0.000075s latency).
MAC Address: 62:91:C0:98:D1:EA (Unknown)
Nmap scan report for attacker (10.30.3.50)
Host is up.
Nmap done: 256 IP addresses (6 hosts up) scanned in 1.99 seconds
pentester@attacker:~/Scripts/Module_3$

```

Realizamos un reverse DNS para poder obtener el dominio es whoami-corp.local

pentester@attacker:~/Scripts/Module_3\$ dig @10.30.3.10 -x 10.30.3.20

```

Nmap done: 1 IP address (1 host up) scanned in 12.23 seconds
pentester@attacker:~/Scripts/Module_3$ dig @10.30.3.10 -x 10.30.3.20

; <<>> DiG 9.18.39-0ubuntu0.24.04.5-Ubuntu <<>> @10.30.3.10 -x 10.30.3.20
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 45801
1 ;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: 83a17164f40a7f7c010000006a5cd7d7e8b288fce6676895 (good)
;; QUESTION SECTION:
;20.3.30.10.in-addr.arpa.      IN      PTR

;; ANSWER SECTION:
20.3.30.10.in-addr.arpa. 300      IN      PTR      edge-web.whoami-corp.local.

;; Query time: 0 msec
;; SERVER: 10.30.3.10#53(10.30.3.10) (UDP)
;; WHEN: Sun Jul 19 13:57:43 UTC 2026
;; MSG SIZE rcvd: 120

```

De acuerdo a lo encontrado vemos un servidor web probable el cual realizamos otro escaneo para poder ver los puertos abiertos que pueda tener y poder encontrar algún hallazgo para poder resolver el laboratorio.

nmap -p- -sS -sC -sV --min-rate 5000 -vvv -n -Pn 10.30.3.20

```

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.0.8 or later
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 10.30.3.50
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 3
|_   vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   256 73:2a:dd:11:c0:44:bd:39:35:3a:77:a4:1d:8b:af:cf (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBz3MoEILjD4HINY2m6UCcofZDiYziz8HGgiX3cFDi+6ibJ7eSET0rrhzUER0qY6eH2LntJqFqTQTc0es+xPhB4=
|_ 256 77:20:a8:1c:77:59:08:90:c7:9a:c0:14:2c:36:5b:3f (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKg6n8i52RVogG0FjZ4FNje3nyXhGyrwwIVhVp2QHRs
80/tcp    open  http      syn-ack ttl 64  nginx/1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-title: Whoami Corp Edge
|_ http-robots.txt: 3 disallowed entries
|_ /archive/ /dev/ /private/
MAC Address: 76:44:DA:6C:0B:8E (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Desde la sesión del atacante listamos lo que contiene en la sesión ya sea directorios o archivos que nos pueda dar una pista para la resolución, el cual encontramos lo siguiente:

```
pentester@attacker:~/Scripts/Module_3$ ls Attack_Surface_Mapping.py Domain_OSINT.sh
TASKS.md passwords.txt subdomains.txt users.
```

Si vemos el contenido del archivo llamado TASKS.md se visualiza lo siguiente:

```
pentester@attacker:~/Scripts/Module_3$ cat TASKS.md
# ShadowMap Brief

Trabaja desde el atacante y conserva evidencias de cada hallazgo.

El formulario de evaluacion esta fuera de la maquina. Usa este entorno para ejecutar recono
cimiento DNS, WHOIS, OSINT, escaneo de puertos, fingerprinting y validacion de credenciales
segun las preguntas entregadas por el instructor.

Herramientas locales:
- Domain_OSINT.sh
- Attack_Surface_Mapping.py
- users.txt
- passwords.txt

No asumas respuestas por archivos locales: valida todo con herramientas.
```

También revisamos los siguientes archivos que están al ingresar por primera vez en la sesión.

```
pentester@attacker:~$ ls
```

```
BRIEF.txt Scripts notes
```

```
pentester@attacker:~$ cat BRIEF.txt
ShadowMap - Briefing operativo

Objetivo: mapear la superficie de ataque de whoami-corp.local y construir la flag final.

Formato de entrega (sin espacios extra):
SHADOWMAP{subdomains_iana_webtech_openports_hosts_os_distro}

Donde cada segmento es un valor obtenido dentro del laboratorio:
subdomains - subdominios DNS resolubles del dominio principal
iana       - Registrar IANA ID del WHOIS interno
webtech    - tecnologia del servidor web (nombre corto, minusculas)
openports  - puertos TCP abiertos en el host web (solo el numero)
hosts      - hosts activos en la red interna del escenario
os         - familia del sistema operativo del objetivo
distro     - distribucion o banner del objetivo

Lee ~/notes/ para saber que medir y con que herramienta.
No necesitas internet externo para completar este laboratorio.
Valida con: sudo bash startlab.sh check (desde el host Linux)
pentester@attacker:~$
```

Encontramos los parámetros que se requiere para armar la flag definitiva para el laboratorio:

SHADOWMAP{subdomains_iana_webtech_openports_hosts_os_distro}

Donde cada segmento es un valor obtenido dentro del laboratorio:

subdomains — subdominios DNS resolubles del dominio principal

iana — Registrar IANA ID del WHOIS interno

webtech — tecnologia del servidor web (nombre corto, minusculas)

openports — puertos TCP abiertos en el host web (solo el numero)

hosts — hosts activos en la red interna del escenario

os — familia del sistema operativo del objetivo

distro — distribucion o banner del objetivo

Primer paso - Subdominios

pentester@attacker:~/Scripts/Module_3\$./Domain_OSINT.sh whoami-corp.local

```

=== Subdomains ===
www.whoami-corp.local 10.30.3.20
portal.whoami-corp.local 10.30.3.20
demo.whoami-corp.local 10.30.3.20
api.whoami-corp.local 10.30.3.20
dev.whoami-corp.local 10.30.3.20
backup.whoami-corp.local 10.30.3.20
intranet.whoami-corp.local 10.30.3.20
support.whoami-corp.local portal.whoami-corp.local.portal.whoami-corp.local.
10.30.3.20
cdn.whoami-corp.local www.whoami-corp.local.www.whoami-corp.local.
10.30.3.20
mail.whoami-corp.local 10.30.3.25
smtp.whoami-corp.local 10.30.3.25
ftp.whoami-corp.local 10.30.3.20
ssh.whoami-corp.local 10.30.3.20
whois.whoami-corp.local 10.30.3.35
vpn.whoami-corp.local 10.30.3.40
old-vpn.whoami-corp.local 10.30.3.41
files.whoami-corp.local 10.30.3.42
=== WHOIS Lookup ===
Domain Name: WHOAMI-CORP.LOCAL
Registry Domain ID: SHADOWMAP-20260704
Registrar WHOIS Server: whois.whoami-corp.local
Registrar URL: https://whoamilabs.dev
Updated Date: 2026-07-04T05:00:00Z
Creation Date: 2026-07-04T05:00:00Z
Registrar Registration Expiration Date: 2027-07-04T05:00:00Z
Registrar: Whoami Labs Training Registrar
Registrar IANA ID: 4242
Registrant Organization: Whoami Corp
Registrant Country: CO
Name Server: NS1.WHOAMI-CORP.LOCAL
Name Server: NS2.WHOAMI-CORP.LOCAL
DNSSEC: unsigned

```


Al validar la cantidad de subdominios que tenemos podemos validar que en total son 17, por lo tanto, tenemos la primera flag el valor de este primer paso (17).

Segundo paso – ID IANA

En este caso validar cual es el ID de la IANA para esto se requiere usar la siguiente línea:

```
whois -h whois.whoami-corp.local whoami-corp.local
```

utilizamos el comando whois que consulta bases de datos públicas para determinar el propietario de un nombre de dominio o dirección IP.

Usamos la flag -h este sirve para usar el servidor WHOIS específico, el servidor WHOIS es whois.whoami-corp.local y finalmente especificamos el dominio al cual se le va a consultar en este caso whoami-corp.local

```
pentester@attacker:~/Scripts/Module_3$ whois -h whois.whoami-corp.local whoami-corp.local
Domain Name: WHOAMI-CORP.LOCAL
Registry Domain ID: SHADOWMAP-20260704
Registrar WHOIS Server: whois.whoami-corp.local
Registrar URL: https://whoamilabs.dev
Updated Date: 2026-07-04T05:00:00Z
Creation Date: 2026-07-04T05:00:00Z
Registrar Registration Expiration Date: 2027-07-04T05:00:00Z
Registrar: Whoami Labs Training Registrar
Registrar IANA ID: 4242
Registrant Organization: Whoami Corp
Registrant Country: CO
Name Server: NS1.WHOAMI-CORP.LOCAL
Name Server: NS2.WHOAMI-CORP.LOCAL
DNSSEC: unsigned
```

Podemos encontrar que el ID de la IANA es 4242, por lo tanto la flag#2 sería: 4242

Tercer paso- Tecnología WEB

Realizamos una petición tipo HEAD (cabecera) no pedimos el contenido de la página esto es más rápido, le pedimos los metadatos.

```
curl -I http://www.whoami-corp.local/
```

La flag -I solo incluye cabeceras es equivalente a hacer una petición HEAD en HTTP, adicional indicamos el dominio (con www) de la máquina objetivo dentro de la red local.

HTTP/1.1 200 OK

Server: nginx/1.24.0 (Ubuntu)

Date: Mon, 20 Jul 2026 14:07:28 GMT

Content-Type: text/html

Content-Length: 868

Last-Modified: Mon, 20 Jul 2026 08:10:44 GMT

Connection: keep-alive

ETag: "6a5dd804-364"

Accept-Ranges: bytes

Flag: nginx

Cuarto paso puerto abiertos de acuerdo con el escaneo al principio de la documentación se detectó los siguientes puertos 21, 22,80.

La flag sería: 3

Quinto paso -hosts activos.

Tomando en cuenta la captura del escaneo que se realizó mostrado al principio de la documentación

IP	Nombre del Host
10.30.3.10	shadowmap-dns.shadowmap_net
10.30.3.20	shadowmap-target.shadowmap_net
10.30.3.25	shadowmap-mail-storage.shadowmap_net
10.30.3.35	shadowmap-whois.shadowmap_net
10.30.3.50	attacker

La Flag sería: 5

Sexto paso – Familia de S.O.

Lo realizamos con la siguiente línea para poder visualizar la familia del sistema operativo del objetivo web.

```

pentester@attacker:~/notes$ sudo nmap -O 10.30.3.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-20 15:37 UTC
Nmap scan report for shadowmap-target.shadowmap_net (10.30.3.20)
Host is up (0.00023s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: B2:A5:E8:0A:E2:CA (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94SVN%E=4%D=7/20%OT=21%CT=1%CU=44138%PV=Y%DS=1%DC=D%G=Y%M=B2A5E
OS:8%TM=6A5E40C0%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=107%TI=Z%CI=Z%I
OS:I=I%TS=22)SEQ(SP=102%GCD=2%ISR=107%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11N
OS:WA%O2=M5B4ST11NWA%O3=M5B4NNT11NWA%O4=M5B4ST11NWA%O5=M5B4ST11NWA%O6=M5B4S
OS:T11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=4
OS:0%W=FAF0%O=M5B4NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(
OS:R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%
OS:W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=
OS:)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%
OS:UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

```

La flag sería: linux

Séptimo paso – Distribución

Procedemos a validar que distribución o banner tiene el objetivo, lo realizamos con la siguiente línea de comando:

```
nmap -sV -p21,22,80 10.30.3.20
```

```

pentester@attacker:~/notes$ nmap -sV -p21,22,80 10.30.3.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-20 15:51 UTC
Nmap scan report for shadowmap-target.shadowmap_net (10.30.3.20)
Host is up (0.00019s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.16 seconds
pentester@attacker:~/notes$

```

De acuerdo con el resultado podemos decir que la flag sería ubuntu.

Una vez ya encontrado todas las flags procedemos a unirlos de acuerdo a lo indicado en la nota que encontramos, para poder obtener la flag definitiva.

```
SHADOWMAP{17_4242_nginx_3_5_linux_ubuntu}
```

```
Acceso al entorno atacante:  
ssh pentester@127.0.0.1 -p 2222  
Password: osint
```

```
Ingresa la flag final (formato SHADOWMAP{ ... }): SHADOWMAP{17_4242_nginx_3_5_linux_ubuntu}
```

```
¡Felicitaciones! Has completado SHADOWMAP.
```

```
TIEMPO TOTAL: 07h 43m 42s
```

```
FECHA Y HORA: 2026-07-20 11:54:27 -0400
```

```
[*] Presiona Ctrl+C para eliminar el laboratorio.
```